

Plano de Segurança Inicial e Hardening: Página HTML com Nginx

1. Caracterização do Serviço Publicado

- **Serviço Escolhido:** Cenário A – Página HTML com Nginx em sistema operativo Linux (Ubuntu Server/Debian).
- **Portas e Protocolos:**
 - Portas nativas: **22/TCP (SSH)** para gestão e administração remota.
 - Portas web: **80/TCP (HTTP)** para acolhimento de tráfego inicial e **443/TCP (HTTPS)** para a entrega segura e encriptada dos conteúdos estatísticos via TLS.
- **Diretório de Publicação:** `/usr/share/nginx/html/` (raiz padrão do Nginx para ficheiros estáticos). [\[1\]](#)
- **Componentes Envolvidos:** Servidor Web Nginx (motor de alto desempenho para ficheiros estáticos) e o sistema operativo base Linux.
- **Dependências Principais:** Utilitário `OpenSSH-Server` para acesso remoto, gestor de pacotes do sistema (`apt`) e módulos nativos do Nginx .

2. Superfície de Ataque

Elemento exposto [1]	Risco	Necessário?	Medida proposta
SSH	Ataques de força bruta e tentativas de intrusão com privilégios administrativos.	Sim	Alterar a porta padrão, desativar o login direto do <i>root</i> e forçar autenticação exclusiva por chaves criptográficas.
HTTP	Interceção de tráfego (Sniffing) e modificação de dados em trânsito.	Sim	Configurar o Nginx para efetuar o redirecionamento imediato (HTTP 301) de todo o tráfego para HTTPS.
HTTPS	Utilização de protocolos antigos (TLS 1.0/1.1) ou cifras vulneráveis a ataques de decifragem.	Sim	Instalar um certificado SSL/TLS (ex: Let's Encrypt) e impor o uso de TLS 1.2 e TLS 1.3.
Base de dados	Não aplicável a este cenário (redução nativa da superfície de ataque).	Não	Garantir que nenhum serviço de base de dados (MySQL/PostgreSQL) está sequer instalado ou ativo.
Diretório web	Listagem de ficheiros expostos (Directory Indexing) e leitura de ficheiros de configuração internos.	Sim	Desativar explicitamente a diretiva <code>autoindex</code> no Nginx e restringir as permissões do sistema de ficheiros Linux.

3. Regras de Firewall

A firewall operará sob a política restritiva de **bloqueio total de entrada por omissão**, abrindo apenas os canais indispensáveis para o tráfego público web e administração controlada.

Serviço	Porta	Decisão	Justificação
SSH	22	Restrito	Porta deve ser alterada (ex: 2222) e o acesso restrito via firewall apenas aos endereços IP dos administradores.
HTTP	80	Aberto	Aberto temporariamente para processar os pedidos iniciais dos utilizadores e forçar a migração para a ligação segura.
HTTPS	443	Aberto	Porta principal do serviço. Disponibiliza a página HTML estática com cifragem de ponta a ponta.
Bases de Dados	3306 / 5432	Fechado	Bloqueado na totalidade. Cenário estático puro que não requer comunicação com bases de dados.

4. Hardening Inicial (6 Medidas Propostas)

1. Desativação da Listagem de Diretórios e Ocultação da Versão do Nginx

- **Ação:** Impedir que utilizadores externos vejam a estrutura de pastas do site e ocultar o número exato da versão do Nginx nos cabeçalhos de erro (evitando que descubram vulnerabilidades conhecidas).
- **Configuração:** Adicionar ou editar no ficheiro de configuração principal `/etc/nginx/nginx.conf` (dentro do bloco `http`):
nginx
server_tokens off;
autoindex off;

2. Configuração de Permissões Estritas no Diretório Web

- **Ação:** Garantir que os ficheiros HTML/CSS pertencem ao administrador e que o utilizador do Nginx (`www-data`) possui apenas permissões estritas de leitura, sem capacidade de escrita.
- **Comandos:**

```
sudo chown -R root:www-data /var/www/html/  
find /var/www/html/ -type d -exec chmod 755 {} \;  
find /var/www/html/ -type f -exec chmod 644 {} \;
```

3. Implementação de Cabeçalhos de Segurança HTTP (Security Headers)

- **Ação:** Mitigar ataques do tipo Cross-Site Scripting (XSS), Clickjacking e sniffing de MIME-types diretamente através das respostas do servidor.
- **Configuração:** Incluir no bloco `server` do ficheiro de configuração do site

nginx

```
add_header X-Frame-Options "SAMEORIGIN" always;
add_header X-Content-Type-Options "nosniff" always;
add_header X-XSS-Protection "1; mode=block" always;
add_header Content-Security-Policy "default-src 'self';
script-src 'self'; style-src 'self';" always;
```

4. Automatização de Atualizações de Segurança do Sistema

- **Ação:** Garantir que o sistema operativo base e o binário do Nginx recebem correções de segurança de forma autónoma.
- **Comando:** Instalar e validar o pacote de atualizações automáticas:

```
sudo apt update && sudo apt install unattended-upgrades -y
sudo dpkg-reconfigure --priority=low unattended-upgrades
```

5. Restrição de Métodos HTTP Permitidos

- **Ação:** Uma página HTML estática apenas necessita de processar pedidos de leitura (GET, HEAD). Métodos de envio de dados ou eliminação devem ser explicitamente rejeitados.
- **Configuração:** No bloco `location /` do ficheiro de configuração do site:

nginx

```
if ($request_method !~ ^(GET|HEAD)$ ) {
    return 405;
}
```

6. Configuração e Ativação da Firewall Perimetral (UFW)

- **Ação:** Implementar as regras definidas na Tarefa 3, blindando o servidor contra acessos em portas não autorizadas.
- **Comandos:**

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 80/tcp
sudo ufw allow 443/tcp
# Substituir pelo IP real do administrador antes de ativar
sudo ufw allow from [IP_ADMIN] to any port 22 proto tcp
sudo ufw enable
```